DESIGN SPEC — AGENT SECURITY ARCHITECTURE

The Rubber Sandbox

Elastic permissions, two models, and an airlock.

6 November 2026 · v0.1 · One-page spec

> **Core idea:** Do not harden the prompt and hope. Give the boundary a physics — it **stretches** for the task, **retracts** when the task ends, **deforms** into rollback instead of breaking, and **stiffens** when something pulls wrong. Rubber inside; one steel door out.

The problem. A language model receives instructions and untrusted content as the same stream of language, so no prompt wording reliably separates them: injection is an architectural problem, not a phrasing problem. Static permissions make it worse — access granted once stays forever, and the moment a fooled agent can send, spend, publish, or delete, a trick becomes a loss.

1 The elastic boundary

PERMISSIONS AS PHYSICS

- **Stretch per task.** Permissions are minted from the owner's actual request — this agent, these contacts, ten minutes — never as standing access.
- **Retract on its own.** When the task ends, access evaporates. Nothing accumulates.
- **Deform, don't break.** Work inside is provisional — drafts, staged changes, snapshots — so a trick rearranges a sandbox that can roll back.
- **Stiffen under stress.** Anomalous reach — unrelated contacts, a new destination, an unusual hour — narrows scope and adds checks, like a bank freezing a card.
- **One steel door.** The outside world has no undo. Sends, spends, publishes, and deletes cross as committed transactions, ideally with the owner's tap.

2 Two models, three kinds of smart

HANDS / SENSES / BONES

Smart model	→	Learning guard	→	Policy bones
Inside the box. Does the work. Never holds the scissors.		Outside the box. Scores everything. Senses, never obeys.		Deterministic rules + provenance tags. Decide what is possible.

- **Why the guard is deliberately simpler.** The smart model is persuadable by design — following language is its job. A classifier-style guard cannot be sweet-talked; it measures and scores, cheaply, on every message and tool call.
- **What the guard learns.** What normal looks like *for this owner* — usual recipients, hours, message shapes, thread patterns. It is the tension sensor that tells the rubber when to stiffen, as bank fraud models do.
- **Bounded learning.** The guard may tighten on its own; loosening requires the owner's confirmed examples, so an attacker cannot slowly boil "normal" toward themselves.

3 The airlock protocol

FORMS, NOT CONVERSATION

The models communicate, but never in free-form dialogue — conversation is the medium the attacker speaks. Forward raw text, and the injection rides the elevator up.

- **Case files, not content.** The guard compiles a stripped dossier: provenance tags, extracted features, suspicious elements as inert tokens — e.g. *RECIPIENT_7 [source: webpage, first seen: today]*. Meaning survives; instruction-ness does not.
- **Schema before sight.** Where content must be seen, a throwaway extractor with no tools and no memory forces it into a fixed form — stated need, requested action, claimed deadline. Only validated output crosses: prose is the threat; a form is data.
- **Narrow questions, constrained answers.** The guard asks one specific question ("Does RECIPIENT_7 plausibly relate to the stated task?"); the smart model replies only with a verdict from a short list, a confidence, and evidence pointers. No free text flows back.

4 Asymmetric trust

THE KEY RULE

> The smart model may **convict** tainted content, but it may never **acquit** it.

- If it flags manipulation, that is believed instantly and the boundary stiffens. If it calls tainted material "fine," that is one vote — policy still routes the case to the owner, who judges outside evidence.
- On clean but merely unusual material, its judgment may carry the decision: the risk there is a false alarm, not a hijack.
- **Only the owner mints gold labels.** Model verdicts never enter training data as ground truth, or an attacker could teach the guard to bless a pattern. Every stiffen-and-ask moment labels the owner's risk taste — prompts fade as the guard gets more *owner*, not more permissive.

5 Honest limits

- Classifiers catch known shapes; novel phrasing can score clean. Provenance decides — and the extractor is the soft spot: uncertain means ask, never act.
- No version secures a fully general agent with unconstrained tools.

6 Build order — boring first

- **v1 (about 80% of the protection):** fixed, word-for-word scripts; provenance tags on every value; an action allowlist; owner approval on first send to anyone new.
- **v2:** the learning guard, anomaly stiffening, and the full airlock. In a scoped workflow — contact, log, fixed script, schedule — provenance is crisp: boring reliability.

Evidence & prior art

Not new in parts: the dual-model split (Willison, 2023), six agent-security patterns (2025), DeepMind's CaMeL — 77% completion *with* provable security vs. 84% undefended on AgentDojo. Fresh here: elasticity as the principle, and asymmetric trust as a rule.

Success looks like: **fooled occasionally, harmed never, interrupted sometimes.**